

MAPEO DETALLADO: PREGUNTAS ENCUESTA ↔ REQUISITOS NORMATIVOS

Tabla de Conformidad NIS2, ENS, ISO 27001, NIST CSF

Versión: 2.0 | **Fecha:** Enero 2026 | **Audiencia:** Auditoría, Compliance, Consultores

Uso: Validar qué preguntas de encuesta mapean a qué requisitos regulatorios

BLOQUE 1: GOBERNANZA Y ESTRATEGIA

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P1.1.1	¿Política ciberseguridad formalizada?	ALTO	Art 17 (Governance)	Org.1	A.5.1	GO-GV	Requisito base, auditado anualmente
P1.1.2	¿Junta Directiva recibe reportes regulares?	ALTO	Art 17	Org.1	A.5.1	GO	Esencial para escalada incidentes NIS2
P1.1.3	¿CISO designado formal con presupuesto?	MODERADO	Art 18 (Capacidad)	Org.2	A.5.2	GO-GV	Obligatorio entidades esenciales NIS2
P1.1.4	¿Plan Estratégico o Ciberseguridad 3-5 años?	MODERADO	Art 21 (Medidas)	Org.3	A.5.3	GO	Alineación business-seguridad
P1.2.1	¿Identificadas obligaciones regulatorias?	ALTO	Todas	General	A.5.1	GO	Prerequisito mapeo cumplimiento
P1.2.2	¿Clasificación NIS2?	CRÍTICO	Art 2 (Scope)	ENS Categoría	N/A	GO	Determina nivel auditoría obligatoria
P1.2.3	¿Plan acción NIS2 formal (si aplica)?	CRÍTICO	Todo	Todo	A.5.1	GO	Deadline 2025-2026, sanciones €7-10M

BLOQUE 2: GESTIÓN DE RIESGOS (MAGERIT MAR)

2.1 Tarea MAR.1: Caracterización de Activos

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P2.1.1	¿Inventario formalizado activos críticos?	ALTO	Art 21(a)	Op.pl.1	A.8.1	ID-AM	Base MAGERIT MAR, CMDB requerida
P2.1.2	¿Valoración impacto dimensiones seguridad?	ALTO	Art 21(a)	Op.pl.1	A.12.6	ID-GV	Cuantificación MAGERIT, escala C/I/D/A/T
P2.1.3	¿Dependencias entre activos mapeadas?	MODERADO	Art 21(a)	Op.pl.1	A.12.6	ID-GV	Cascadas de riesgo, impacto acumulado

2.2 Tarea MAR.2: Caracterización de Amenazas

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P2.2.1	¿Análisis formal amenazas (STRIDE, CAPEC)?	ALTO	Art 21(a)	Op.pl.1	A.12.6	ID-GV	Mapa de riesgos requerido anualmente
P2.2.2	¿Estimada frecuencia /ARO basada datos?	MODERADO	Art 21(a)	Op.pl.1	A.12.6	ID-GV	Probabilidad histórica + benchmarking
P2.2.3	¿Degradación potencial cuantificada?	MODERADO	Art 21(a)	Op.pl.1	A.12.6	ID-GV	% pérdida valor por escenario FAIR

2.3 Tarea MAR.3: Caracterización de Salvaguardas

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P2.3.1	¿Inventario salvaguardas + Decl. Aplicabilidad?	ALTO	Art 21	Mp (protección)	A.Anexo A	PR	Declaración Aplicabilidad ISO 27001
P2.3.2	¿Madurez salvaguardas evaluada (L0-L5)?	MODERADO	Art 21	Mp	A.Anexo A	PR	Eficacia controles medida, auditable
P2.3.3	¿Insuficiencias identificadas y priorizadas?	MODERADO	Art 21	Mp	A.Anexo A	PR	Informe de insuficiencias MAGERIT

2.4 Tarea MAR.4: Estimación de Riesgo Residual

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P2.4.1	¿Riesgo residual calculado y reportado?	ALTO	Art 21(a)	Op.pl.1	A.12.6	ID-RM	Matriz de riesgo, estado riesgos
P2.4.2	¿Análisis impacto acumulado/cascadas?	MODERADO	Art 21(a)	Op.pl.1	A.12.6	ID-GV	Dependencias activos, análisis Montecarlo
P2.4.3	¿Decisiones tratamiento riesgo documentadas?	ALTO	Art 21(a)	Op.pl.1	A.12.7	ID-RM	Mitigar/transferir / compartir /aceptar, log cambios

BLOQUE 3: INDICADORES Y MÉTRICAS

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P3.1.1	¿Marco KPI/KRI formal (GQM + NIST CSF)?	MODERADO	Art 21	Op.mon.2	A.18.1	GO-RM	Governanza medición, tableros ejecutivos
P3.1.2	¿Madurez reportada por dominio NIST?	MODERADO	Art 21	Op.mon.2	A.18.2	GO-RM	Benchmarking sectorial (Identify 68%, Detect 64%)
P3.1.3	¿Aplicadas 46 métricas INCIBE ciberresiliencia?	MODERADO	Art 21	Op.mon.2	A.18	GO-RM	9 dominios, 4 metas, auditable
P3.2.1	¿Riesgo cuantificado FAIR/ALE (€)?	MODERADO	Art 21	Op.pl.1	A.12.6	ID-RM	Impacto financiero para decisiones inversión
P3.2.2	¿ROI análisis inversiones seguridad?	MODERADO	Art 21	Op.pl.1	A.12.7	ID-RM	Payback period, justificación presupuesto
P3.2.3	¿Riesgo residual comunicado a Junta €?	MODERADO	Art 17	Op.mon.2	A.5.1	GO	Transparencia C-Suite, decisiones informadas
P3.3.1	¿Cobertura salvaguardas monitorada (%)?	BAJO	Art 21	Op.mon.2	A.18.1	PR-IS	KPI % activos críticos cubiertos

P3.3.2	¿Métricas eficiencia seguridad calculadas ?	BAJO	Art 21	Op.mon.2	A.18.2	GO-RM	Horas/ 1000 usuarios, cost/risk unit
---------------	---	------	--------	----------	--------	-------	--

BLOQUE 4: VULNERABILIDADES Y PRUEBAS PENETRACIÓN

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P4.1.1	¿Proceso gestión vulnerabilidades (CVSS)?	ALTO	Art 21(e)	Mp.com.1	A.14.2	DE-VE	CVSS + EPSS scoring, herramienta (Qualys)
P4.1.2	¿SLA remediación vulnerabilidades críticas?	ALTO	Art 21(e)	Mp.com.1	A.14.2	DE-VE	<7 días recomendado ENS ALTA
P4.1.3	¿Parcheo sistemático SO y aplicaciones?	ALTO	Art 21(e)	Mp.com.1	A.14.2	DE-VE	Calendario, pre-testing, rollback
P4.1.4	¿% sistemas vulnerables críticos reportado?	MODERADO	Art 21	Op.mon.2	A.18.1	PR-IS	KRI crítico, métrica mensual
P4.2.1	¿Pruebas penetración regulares?	ALTO	Art 21(c) (d)	Mp.eve	A.14.2	DE-PE	Anual mínimo (externo), semestrales recomendado
P4.2.2	¿Alcance pentest (ext+int+wireless+física)?	ALTO	Art 21(c) (d)	Mp	A.14.2	DE-PE	OWASP/PTES/OSSTMM metodología
P4.2.3	¿Plan remediación pentesting críticos?	MODERADO	Art 21(c) (d)	Mp	A.14.2	PR	Re-testing 90 días post-remediación

P4.2.4	¿Pruebas seguridad física (tailgating)?	MODERADO	Art 21(c)	Mp.seg	A.11	PR-PS	OSSTMM "Seguridad Humana"
P4.3.1	¿SAST/DAST en ciclo desarrollo (CI/CD)?	MODERADO	Art 21(c)	Op.exp.5	A.14.2	PR-SD	DevSecOps, secure by design
P4.3.2	¿Registro vulnerabilidades vs. remedidas (%)?	MODERADO	Art 21	Op.mon.2	A.18.1	DE-VE	Trending, resolución >95% en 90d

BLOQUE 5: SIEM Y MONITORIZACIÓN

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P5.1.1	¿SIEM operativo?	ALTO	Art 21(f)	Op.exp.8	A.12.4	DE	Infraestructura base detección
P5.1.2	¿% logs capturados y centralizados?	ALTO	Art 21(f)	Op.exp.8	A.12.4	DE	>90% requerido nivel L4
P5.1.3	¿Escaneo activo + pasivo red?	MODERADO	Art 21(f)	Op.exp.9	A.14.1	DE	Asset discovery, vulnerabilidades
P5.2.1	¿Reglas personalizadas SIEM (falsos positivos)?	ALTO	Art 21(f)	Op.exp.8	A.12.4	DE	<10% false positive rate L5
P5.2.2	¿UEBA (análisis comportamiento usuarios)?	MODERADO	Art 21(f)	Op.exp.8	A.12.4	DE	Detección anomalías, insider threat
P5.2.3	¿Feeds threat intelligence integrados?	MODERADO	Art 21(f)	Op.exp.8	A.12.4	DE	MITRE ATT&CK, geolocalización, APT context
P5.3.1	¿Volumen alertas y % investigadas?	ALTO	Art 21(f)	Op.exp.8	A.12.4	DE	Meta: <50 alertas/día, >95% investigadas
P5.3.2	¿Playbooks SOAR automatizados?	MODERADO	Art 21(g)	Op.exp.7	A.16	RS	Orquestación respuesta automática

P5.3.3	¿Tiempo de detección a investigación?	ALTO	Art 21(g)	Op.exp.7	A.16	RS	<1 hora L5 (automático), <4h L3
P5.4.1	¿Reportes SIEM automáticos (diarios/mensuales)?	MODERADO	Art 21(g)	Op.exp.8	A.18.2	RS	Dashboards continuo, auditable
P5.4.2	¿Análisis forense incidentes (root cause)?	MODERADO	Art 21(g)	Op.exp.7	A.16.1	RS	Post-mortem, lecciones aprendidas

BLOQUE 6: CAPACITACIÓN Y CONCIENCIACIÓN

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P6.1.1	¿Programa formación seguridad formal?	MODERADO	Art 21(i)	Org.2	A.6.2	PR-AW	Obligatorio NIS2, ~2% presupuesto IT
P6.1.2	¿% empleados capacitación completada?	MODERADO	Art 21(i)	Org.2	A.6.2	PR-AW	Meta >95% anual, L3 mínimo
P6.1.3	¿Cobertura temas seguridad (MAGERT, RGPD)?	MODERADO	Art 21(i)	Org.2	A.6.2	PR-AW	Contenido específico por rol
P6.1.4	¿Tracks diferenciados (ejecutivos/TI/usuarios)?	BAJO	Art 21(i)	Org.2	A.6.2	PR-AW	Personalización por competencia
P6.2.1	¿Campañas phishing simuladas?	MODERADO	Art 21(i)	Org.2	A.6.2	PR-AW	Mensualmente (L4), indicador conciencia
P6.2.2	¿Tasa clics phishing promedio?	MODERADO	Art 21(i)	Org.2	A.6.2	PR-AW	Meta <5% (L5), >30% es crítico
P6.2.3	¿Campañas sensibilización adicionales?	BAJO	Art 21(i)	Org.2	A.6.2	PR-AW	Newsletter, eventos, newsletters

P6.3.1	¿Métricas efectividad formación medidas?	MODERADO	Art 21(i)	Org.2	A.6.2	PR-AW	Pre/post tests, conocimientos adquiridos
P6.3.2	¿Reducción incidentes por error humano?	MODERADO	Art 21(i)	Org.2	A.6.2	PR-AW	Trending >25% reducción anual
P6.3.3	¿Reporta ROI concienciación a Junta?	BAJO	Art 21(i)	Org.2	A.6.2	PR-AW	Justificación inversión formación

BLOQUE 7: RESILIENCIA Y CONTINUIDAD

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P7.1.1	¿Política backup formal + RTO/RPO?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	CRÍTICO: Requisito NIS2 explícito
P7.1.2	¿Frecuencia backup sistemas críticos?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	Horario L5, <1h RPO
P7.1.3	¿Pruebas restauración backups?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	Mensual L5, anual L2
P7.1.4	¿Backups segregados, encriptados?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	Offline, >1 ubicación, inmutable
P7.2.1	¿Plan Recuperación Desastres (DRP/BCP)?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	Documento formal, probado periódicamente
P7.2.2	¿Funciones Críticas mapeadas + prioridad?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	Dependencias, matriz criticidad
P7.2.3	¿Sitio alternativo recuperación?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	<30min RTO, sitio geográf. lejano
P7.3.1	¿Redundancia componentes críticos?	ALTO	Art 21(h)	Op.exp.6	A.17.1	RC	N+1 mínimo, N+2 recomendado
P7.3.2	¿Análisis impacto empresarial (BIA)?	MODERADO	Art 21(h)	Op.exp.6	A.17.1	RC	Daño/hora por servicio (€)

P7.4.1	¿Chaos engineering / simulacros?	MODERADO	Art 21(h)	Op.exp.6	A.17.1	RC	Trimestral L5, anual L3
P7.4.2	¿Cumplimiento RTO/RPO en ejercicios?	MODERADO	Art 21(h)	Op.exp.6	A.17.1	RC	>95% cumplimiento L4
P7.4.3	¿Test recuperación ransomware?	MODERADO	Art 21(h)	Op.exp.6	A.17.1	RC	Trimestral, validar backup limpio

BLOQUE 8: CUMPLIMIENTO NORMATIVO

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P8.1.1	¿Auditoría ENS formal realizada?	ALTO	Todo	Todo	A.5.1	GO	BÁSICA: auto-eval; MEDIA/ALTA: externa obligatoria
P8.1.2	¿Categoría ENS determinada?	ALTO	Todo	Categoría	Todo	GO	BÁSICA/MEDIA/ALTA, proporcionalidad
P8.1.3	¿MAGERTMAR completo (4 tareas)?	ALTO	Art 21(a)	Op.pl.1	A.12.6	ID	Base auditoría ENS, documentable
P8.2.1	¿Evaluación aplicabilidad NIS2?	CRÍTICO	Art 2 (Scope)	Todo	Todo	GO	Determina obligaciones, sanciones
P8.2.2	¿Auditoría ISO 27001 vigente (si Esencial)?	CRÍTICO	Art 21	Todo	Certificación	GO	Obligatorio para entidades esenciales
P8.2.3	¿Plan acción NIS2 en ejecución?	CRÍTICO	Todo	Todo	Todo	GO	Timeline y hitos, responsables
P8.3.1	¿Gestión incidentes <72h notificación?	CRÍTICO	Art 21(g)	Op.exp.7	A.16.1	RS	CRÍTICO: Requisito NIS2 explícito
P8.3.2	¿Policy criptografía CCN-STIC?	ALTO	Art 21(b)	Mp.com.2	A.10.1	PR	AES-256 (reposo), TLS 1.3 (tránsito)

P8.3.3	¿Auditoría proveedor es + SBOM?	MODERA DO	Art 21(d)	Op.ven	A.15.1	PR	Cadena suministr o, software BOM
P8.3.4	¿Segurida d diseño (DevSecO ps)?	MODERA DO	Art 21(c)	Op.exp.5	A.14.2	PR-SD	Secure by design, en cada release
P8.4.1	¿DPIA privacida d datos personale s?	MODERA DO	RGPD Art 35	Privacida d	A.25	GO	Obligatori o RGPD, LOPDGDD
P8.4.2	¿DPO designado ?	MODERA DO	RGPD Art 37	Privacida d	A.25	GO	Contacto publicado autoridad es

BLOQUE 9: INCIDENTES Y RESPUESTA

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P9.1.1	¿Plan respuesta incidentes formal?	ALTO	Art 21(g)	Op.exp.7	A.16	RS	Documento, roles, SLA
P9.1.2	¿CSIRT/SOC 24/7 disponible?	ALTO	Art 21(g)	Op.exp.7	A.16	RS	On-call mínimo, 24/7 recomendado
P9.1.3	¿Todos incidentes registrados + clasificados?	ALTO	Art 21(g)	Op.exp.7	A.16.1	RS	CVSS scoring, trazabilidad
P9.2.1	¿Análisis post-mortem formal (>CVSS 7)?	MODERADO	Art 21(g)	Op.exp.7	A.16.1	RS	Root cause, lecciones aprendidas
P9.2.2	¿Lecciones aprendidas comunicadas org?	MODERADO	Art 21(g)	Op.exp.7	A.16.1	RS	Newsletter, sesiones aprendizaje
P9.3.1	¿Número incidentes 12 meses?	BAJO	Art 21(g)	Op.exp.7	A.16.1	RS	Baseline trending, benchmark
P9.3.2	¿Tiempo promedio contención?	MODERADO	Art 21(g)	Op.exp.7	A.16.1	RS	Meta <2h L5, <8h L3
P9.3.3	¿Incidente significativo último tiempo?	BAJO	Art 21	Op.exp.7	A.16	RS	Lecciones aplicadas validar

BLOQUE 10: MADUREZ GENERAL Y OBSERVACIONES

# Pregunta	Pregunta	Respuesta L1-L2 = Riesgo	Mapeo NIS2	Mapeo ENS	Mapeo ISO 27001	Mapeo NIST CSF	Observaciones
P10.1.1	¿Auto-evaluación madurez general?	BAJO	Todo	Todo	A.5.1	GO	Síntesis de encuesta, validación interna
P10.1.2	¿Confianza a respuestas (1-5)?	BAJO	N/A	N/A	N/A	N/A	Calidad datos, sesgo respondente
P10.2	¿Top 3 riesgos / 3 salvaguardas?	MODERADO	N/A	N/A	A.12.7	ID-RM	Priorización acción, consenso
P10.3	¿Contexto organizacional (sector/tamaño)?	BAJO	N/A	N/A	N/A	N/A	Interpretación riesgos aceptables

MATRIZ DE CONFORMIDAD REGULATORIA

Cálculo por Requisito NIS2:

Conformidad (%) = (Preguntas L3+ / Total preguntas requisito) × 100

Ejemplo: Art 21(a) "Análisis Riesgos"

- Preguntas: P2.1.1, P2.1.2, P2.1.3, P2.2.1, P2.2.2, P2.2.3, P2.4.1, P2.4.2, P2.4.3
- Si 6 de 9 están en L3+: Conformidad = 67% (MODERADO)
- Si <50%: INCUMPLIMIENTO, plan remediación obligatorio

Requisitos NIS2 Críticos (Menor incumplimiento = Mayor riesgo):

Requisito	Artículos	Preguntas Encuesta	Riesgo Sanciones
Análisis Riesgos	Art 21(a)	P2.1-2.4	€10M esencial
Continuidad (RTO/RPO)	Art 21(h)	P7.1-7.4	€10M esencial
Gestión Incidentes (72h)	Art 21(g)	P9.1, P8.3.1	€10M esencial
Criptografía	Art 21(b)	P8.3.2	€10M esencial
Cadena Suministro	Art 21(d)	P8.3.3	€10M esencial
Gobernanza	Art 17-18	P1.1-1.2	€10M esencial

Matriz de Riesgo Regulatorio:

Conformidad NIS2 %	Riesgo Regulatorio	Acción Recomendada
>80%	BAJO	Mantenimiento, auditoría anual
50-80% trimestral	MODERADO	Plan acción 90 días, seguimiento
20-50%	ALTO	Escalación Junta, inversión inmediata
<20%	CRÍTICO	Consultoría externa, timeline 30 días

APÉNDICE: CONTROL VALIDATION

Para validar respuestas de encuesta:

1. Revisar evidencia documentada:
2. Política seguridad: ¿Existe, aprobada, fecha revisión? (P1.1.1)
3. Informe análisis riesgos: ¿MAGERIT MAR 4 tareas? (P2.1-2.4)
4. Incidentes último año: ¿Registro formal, CVSS scoring? (P9.3.1)
5. Preguntas confirmación:
6. Si responde "L5 SIEM", preguntar: ¿% de logs capturados, false positive rate, pruebas penetración último mes?
7. Si responde "L1 Auditoría ENS", preguntar: ¿Cuándo fue última revisión, quién la hizo?
8. Inconsistencias típicas: (investigar)
9. L5 Gobernanza pero L1 Respuesta Incidentes (posible defecto ejecución)
10. L1 MAGERIT pero L4 Vulnerabilidades (posible tooling sin framework)
11. L1 Formación pero L4 Cifrado (enfoque desbalanceado)

Incidentes último año: ¿Registro formal, CVSS scoring? (P9.3.1)

Preguntas confirmación:

Si responde "L1 Auditoría ENS", preguntar: ¿Cuándo fue última revisión, quién la hizo?

Inconsistencias típicas: (investigar)

© 2026 Mapeo Normativo Kit MAGERIT-NIS2-ENS | Consorcio Ciberseguridad

Tabla de referencia para validación conformidad regulatoria. Actualizar anualmente por cambios legislativos.